MDM GRC READINESS & CONTROL ASSURANCE CASE STUDY

MDM-D11

Findings and Remediation Register

Deliverable 11 of 15 in a portfolio case study on readiness and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company. Cross-references to other deliverables use their MDM-D numbers.

Prepared by
Ali Fathi Aldhabiki
Cybersecurity Governance, Risk & Compliance (GRC)
linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Notice
The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

Findings and Remediation Register

MDM-D11

1. Purpose and Scope

This document rates the findings raised in MDM-D10, analyses the gaps behind them and sets the remediation actions. It also records the gaps found outside the test sample.

It covers findings MDM-FND-001 to MDM-FND-008 from the ten tests in MDM-D10. It also covers MDM-FND-009, the requirements in MDM-D07 that have no control in MDM-D05, and items whose evidence was Partial or Not Provided in MDM-D09.

CTL-006, CTL-008, MDM-D07 sections 4.6 to 4.13 and 4.16, and section 5.2 are out of scope. They move to the next testing cycle.

Accepting residual risk is a decision for the Risk Owner named in MDM-D04, not the Control Owner. Items that need that decision are listed in Section 6 and decided in MDM-D12.

No tenant was configured. All findings, ratings and dates are simulated.

2. Method

2.1 Finding Types

Each finding is classified by one question: would the control fail even if it ran exactly as written?

Type	Test Question	Remediation Focus
Design	Would the control miss the requirement even if performed exactly as written?	Change the control design or add a control.
Operating	Is the design sufficient, but the control was not performed as written or there is no evidence that it was?	Perform the control as designed and keep evidence.

2.2 Gap Categories

Category	Basis	Severity
Tested Finding	A test in MDM-D10 failed or was partially effective.	Rated
Confirmed Design Gap	MDM-D05 or MDM-D07 shows that no control or owner exists for a requirement.	Rated
Assurance Gap	The item was not tested and its evidence was Partial or Not Provided in MDM-D09. Its effectiveness is unknown.	Not rated

An Assurance Gap shows the inherent risk level of its linked risk from MDM-D04 for context only. That level is not the gap's severity.

2.3 Severity Rating

Severity uses the Impact and Likelihood scales and the score bands in MDM-D04. It rates the exposure the finding leaves open, not the inherent risk of the linked risk.

Rule	Description
R1 – Scales	Use the MDM-D04 Impact and Likelihood scales and score bands. No other scale is used.
R2 – Impact	Rate what happens if the gap is exploited, limited to the scope it affects, such as iOS only or Android only.
R3 – Likelihood	Rate from the simulated evidence: how often the exception occurred and whether a documented compensating control exists. Limited harm is reflected here, not in the MDM-D10 test result.
R4 – Ceiling	A finding's severity cannot exceed the inherent risk level of its linked risk in MDM-D04.
R5 – Escalation	An Impact score of 5 requires management review, as in MDM-D04.
R6 – Override	Any change to the calculated severity is justified in writing in the register.

2.4 Remediation Timelines

Severity	Remediation Due
Critical	30 days
High	60 days
Medium	90 days
Low	180 days

These timelines are a project convention, not a framework requirement. They run from the date the Control Owner agrees the finding.

3. Findings Register

The register lists every rated item: Tested Findings and Confirmed Design Gaps. Assurance Gaps are listed in Section 4.3 only.

Finding	Title	Category	Test	Control	Risk	Type	Score (I × L)	Severity	Control Owner	Due
MDM-FND-001	iOS Share extension moves corporate files outside managed apps	Tested Finding	MDM-TST-001	MDM-CTL-002	MDM-RSK-002	Design	2 × 4 = 8	Medium	IT Operations Manager	90 days
MDM-FND-002	Noncompliant corporate iPhone reaches OneDrive through the app protection grant	Tested Finding	MDM-TST-002	MDM-CTL-002	MDM-RSK-002	Operating	3 × 3 = 9	Medium	IT Operations Manager	90 days
MDM-FND-003	No record of the CISO review of the IT Operations Manager's administrative access	Tested Finding	MDM-TST-003	MDM-CTL-005	MDM-RSK-005	Operating	3 × 2 = 6	Medium	CISO	90 days

Finding	Title	Category	Test	Control	Risk	Type	Score (I × L)	Severity	Control Owner	Due
MDM-FND-004	Monthly compliance baseline review missing for the first month	Tested Finding	MDM-TST-005	MDM-CTL-003	MDM-RSK-003	Operating	3 × 2 = 6	Medium	IT Operations Manager	90 days
MDM-FND-005	Corporate Android devices unlock without a PIN shortly after automatic screen-off	Tested Finding	MDM-TST-006	MDM-CTL-001	MDM-RSK-001	Design	3 × 2 = 6	Medium	IT Operations Manager	90 days
MDM-FND-006	Contractor access block verified by account status only, and not escalated	Tested Finding	MDM-TST-007	MDM-CTL-007	MDM-RSK-007	Operating	3 × 2 = 6	Medium	IT Operations Manager	90 days
MDM-	Wipe of	Teste	MDM-	None	None	Opera	3 × 2	Medi	IT	90

Finding	Title	Category	Test	Control	Risk	Type	Score (I × L)	Severity	Control Owner	Due
FND-007	a lost device not confirmed, with no owner or follow-up date	d Finding	TST-008	in MDM-D05 (MDM-D07 Section 5.9)	in MDM-D04; rated against MDM-RSK-001	ting	= 6	um	Operations Manager (interim)	days
MDM-FND-008	No retention period set for BYOD activation records	Tested Finding	MDM-TST-009	None in MDM-D05 (MDM-D07 Section 4.17)	None in MDM-D04; rated against MDM-RSK-006	Operating	2 × 2 = 4	Low	IT Operations Manager (interim)	180 days
MDM-FND-009	MDM-D07 requirements on encryption, data removal, the BYOD notice and browser access have no control, owner	Confirmed Design Gap	None (see Section 4.2)	None in MDM-D05	None in MDM-D04; rated against MDM-RSK-001	Design	3 × 2 = 6	Medium	CISO	90 days

Finding	Title	Category	Test	Control	Risk	Type	Score (I × L)	Severity	Control Owner	Due
	or risk									

3.1 Rating Rationale

Finding	Impact	Likelihood
MDM-FND-001	2 – Minor. The file left the managed apps but stayed encrypted and the receiving app could not open it. No confidential content was exposed. The organization loses control of where the copy sits. Scope: iOS BYOD only.	4 – Likely. The Share extension path is open to every iOS BYOD user at all times, with no barrier. Encryption is counted in Impact, not again here.
MDM-FND-002	3 – Moderate. Corporate files in OneDrive remain reachable on a corporate device that failed the compliance baseline. Scope: corporate iOS devices without the OneDrive app configuration.	3 – Possible. The device must first fall out of compliance, which MDM-TST-005 shows does occur. App protection on corporate devices was not tested, so it is not counted as a compensating control.
MDM-FND-003	3 – Moderate. The unreviewed account holds the broadest Intune access in the team. Misuse could weaken security settings across corporate devices, as in MDM-RSK-005. Scope: one account.	2 – Unlikely. The access was approved by the CISO and matches its approved scope (MDM-TST-003, steps 2 and 6). Harm requires that access to become excessive and then be misused before the next review.
MDM-FND-004	3 – Moderate. A stale baseline would let outdated corporate devices count as compliant and reach confidential documents, as in MDM-RSK-003. Scope: all corporate devices.	2 – Unlikely. Automated enforcement and the threshold change process passed (MDM-TST-005, steps 3, 4, 6 and 9), and the later two monthly reviews took place. Harm requires the baseline to fall behind in the missed month and a vulnerable device to be compromised.
MDM-FND-005	3 – Moderate. A person who finds a lost device inside the window	2 – Unlikely. Harm requires the device to be lost and woken by someone else

Finding	Impact	Likelihood
	can open it without a PIN and reach confidential documents, as in MDM-RSK-001. Scope: corporate Android devices only.	inside a short window after screen-off. Strong PINs, the five-minute lock and power-button lock all passed (MDM-TST-006, steps 4–7 and 9). Only a 15-second wake was tested, so the full window length is unknown.
MDM-FND-006	3 – Moderate. If a revocation silently failed, a former contractor could keep viewing or editing confidential team documents, as in MDM-RSK-007. Scope: contractor departures.	2 – Unlikely. All three revocations were completed on time (MDM-TST-007, step 4), and a disabled account lost access in 3 minutes (step 8). Harm requires a revocation to fail and the failure to go unnoticed, which is what verification and escalation should catch.
MDM-FND-007	3 – Moderate. If the wipe never completed, confidential data stays on a lost device, as in MDM-RSK-001. Scope: one lost device.	2 – Unlikely. The wipe was issued on the day of the report (MDM-TST-008, step 5), and wipe capability works on both platforms (steps 8–14). Harm requires the wipe to stay incomplete and the device passcode to be bypassed.
MDM-FND-008	2 – Minor. Activation records hold limited employee data: identity, notice version, acknowledgment time and approvals. Keeping them without limit widens what could be seen if access were misused, as in MDM-RSK-006. Scope: all BYOD users.	2 – Unlikely. Repository access is limited to authorized roles (MDM-TST-009, step 7). Harm requires that restriction to fail or be misused.
MDM-FND-009	3 – Moderate. If a capability stopped working, no owner or review would detect it. The worst case is data left on a lost device, as in MDM-RSK-001, together with a gap against NCA ECC 2-6-3-3. Scope: four requirement areas.	2 – Unlikely. Three of the four areas worked when tested (MDM-TST-001, 005 and 008 to 010). Harm requires a capability to degrade and the change to go unnoticed. Encryption in transit is unverified and is not counted here (Section 4.3).

MDM-FND-007 and MDM-FND-008 have no linked risk in MDM-D04 and no control in MDM-D05 (known gap 1). Each is rated against the closest risk with a matching scenario, which also

sets its ceiling: MDM-RSK-001 for FND-007 and MDM-RSK-006 for FND-008. The IT Operations Manager owns both until a control and owner are defined (Section 4.2).

No rating exceeds the ceiling set by its linked or closest risk. If evidence shows the FND-001 copy can be read outside managed apps, its Impact is re-rated to 3.

For MDM-FND-003, the CISO owns the control and also performs the missed review. Closure is therefore validated by Internal Audit, not by the CISO.

4. Gap Analysis

4.1 Tested Findings

Each row traces one tested finding from what was observed to the risk it leaves open. Current State is taken from the MDM-D10 test steps. Required is taken from MDM-D05, MDM-D07 or MDM-D08.

Finding	Current State	Required	Gap	Resulting Risk
MDM-FND-001	On iOS BYOD, the Share extension moves corporate files to unmanaged apps. The files stay encrypted. Other transfer paths are blocked (MDM-TST-001, step 14).	Corporate files remain in approved apps and storage. Transfers to unapproved apps are restricted (MDM-D07 Section 4.4; MDM-CTL-002).	The App Protection setting cannot block this path on unenrolled iOS devices. No alternative control is defined.	MDM-RSK-002: encrypted copies leave organizational control. Medium (8).
MDM-FND-002	A noncompliant corporate iPhone reaches OneDrive through the app protection grant. The OneDrive app configuration does not exist (MDM-TST-002, steps 11–12; MDM-EVD-007).	Noncompliant corporate devices are blocked from corporate services (MDM-D08 A-01; MDM-CTL-002).	The required app configuration was not deployed, so the compliance requirement can be bypassed in OneDrive.	MDM-RSK-002: corporate files reachable on a device that failed the baseline. Medium (9).
MDM-FND-003	The IT Operations Manager's access has no recorded CISO review. Team access reviews are complete	The CISO reviews the manager's access at least every three	The review was not performed or not recorded.	MDM-RSK-005: the broadest administrative account runs without

Finding	Current State	Required	Gap	Resulting Risk
	(MDM-TST-003, step 9; MDM-EVD-030).	months, with the reviewer and decision recorded (MDM-CTL-005; MDM-D07 Section 5.4).		independent review. Medium (6).
MDM-FND-004	Two monthly baseline reviews exist. The first month is missing. Automated enforcement works (MDM-TST-005, step 5; MDM-EVD-014).	One baseline review each month (MDM-CTL-003; MDM-D07 Sections 3.3–3.8).	One monthly review was not performed.	MDM-RSK-003: a stale baseline could let outdated devices count as compliant. Medium (6).
MDM-FND-005	Corporate Android devices unlock without a PIN 15 seconds after automatic screen-off. No approved immediate-lock configuration exists (MDM-TST-006, steps 3 and 8; MDM-EVD-002).	Authentication is required immediately after the device locks (MDM-D07 Section 3.1; MDM-CTL-001).	The standard sets the requirement but defines no Android configuration to meet it.	MDM-RSK-001: a lost device can be opened inside the grace window. Medium (6).
MDM-FND-006	One of three contractor departures was verified by account status only, and was not escalated (MDM-TST-007, steps 5–6; MDM-EVD-046, 047).	Effective blocking is verified for each departure. Account status alone is not accepted. Incomplete actions are escalated to the IT Operations Manager (MDM-D07 Sections 5.7–5.8; MDM-CTL-	Verification and escalation were not performed as required.	MDM-RSK-007: a failed revocation could go unnoticed. Medium (6).

Finding	Current State	Required	Gap	Resulting Risk
		007).		
MDM-FND-007	The wipe of a lost device was issued on the day of the report, but completion was not confirmed. No owner or follow-up date was recorded (MDM-TST-008, steps 6–7; MDM-EVD-060).	An unconfirmed wipe stays open with an owner and a follow-up date (MDM-D07 Section 5.9).	Confirmation and follow-up were not performed. The requirement has no control in MDM-D05.	Closest risk MDM-RSK-001: data may remain on a lost device. Medium (6).
MDM-FND-008	Activation records are complete and access is restricted, but no retention period is set (MDM-TST-009, step 8; MDM-EVD-064).	The retention period is confirmed before operational use (MDM-D07 Section 4.17).	BYOD activation went live before the retention period was confirmed. The requirement has no control in MDM-D05.	Closest risk MDM-RSK-006: employee data kept without limit. Low (4).

4.2 Confirmed Design Gaps

MDM-FND-009 records one root cause: MDM-D05 was not updated when MDM-D07 added requirements traced only to MDM-D06. These requirements have no control, no Control Owner and no risk in MDM-D04. One finding covers all four areas because they share that cause.

Area	Current State	Required	Gap	Resulting Risk
Encryption	Encryption at rest works on corporate devices and in BYOD apps (MDM-TST-001, step 16; MDM-TST-005, step 7). Encryption in transit is unverified (Section 4.3).	MDM-D07 encryption requirements, including Section 5.1 for data in transit.	No control in MDM-D05, no owner and no linked risk.	Loss of encryption could go undetected.
Data removal	Selective and full wipe work on both platforms (MDM-TST-008).	MDM-D07 Sections 4.14, 4.15 and 5.9.	No control in MDM-D05, no owner and no	Data may remain on lost or

Area	Current State	Required	Gap	Resulting Risk
	Confirmation of a lost-device wipe was not followed up (MDM-FND-007).	NCA ECC 2-6-3-3.	linked risk. The ECC requirement is met technically but has no assigned accountability.	departed devices (closest: MDM-RSK-001, MDM-RSK-007).
BYOD notice	The notice, activation gate and records work (MDM-TST-009). No retention period is set (MDM-FND-008).	MDM-D07 Section 4.17.	No control in MDM-D05, no owner and no linked risk.	Employee data handled without a defined owner (closest: MDM-RSK-006).
Browser access	Mobile browser access is blocked, and approved apps still work (MDM-TST-010, Effective).	MDM-D06 browser prohibition; MDM-D08 Section 3.3 (MDM-CAP-003).	No control in MDM-D05 and no linked risk. The block runs as a Conditional Access policy without a control record.	Changes to the block could go unreviewed.

The technical capabilities work in the simulation. The gap is governance: no one is accountable for keeping them working, and no risk tracks them.

4.3 Assurance Gaps

These items were not tested, and their evidence in MDM-D09 was Partial or Not Provided. Their effectiveness is unknown, so they are not rated. The linked risk level is shown for context only.

Item	Evidence Status	Why Not Rated	Linked Risk (context only)	Next Step	Owner
MDM-CTL-004 Access policy change management	MDM-EVD-023 Not Provided	Not in the test sample, and no evidence to review.	MDM-RSK-004, Medium (6)	Provide MDM-EVD-023 and test the control in the next cycle.	IT Operations Manager
Corporate	MDM-	The network path	None in	Provide MDM-	IT

Item	Evidence Status	Why Not Rated	Linked Risk (context only)	Next Step	Owner
data protection in transit (MDM-D07 Section 5.1)	EVD-057 Not Provided	was not reviewed. A device-side test cannot show proxy or TLS inspection.	MDM-D04 (part of MDM-FND-009)	EVD-057 and review the network path.	Operations Manager
Enterprise user MFA (MDM-D08 Section 4.5, assumption A-06)	MDM-EVD-069 Partial	The IAM owner did not confirm MFA coverage. The design depends on it but does not control it.	Enterprise dependency, no risk in MDM-D04	Obtain written coverage confirmation from the IAM owner. If coverage is incomplete, raise a finding.	CISO, with the IAM owner

Items deferred in MDM-D10 Section 5 with Accepted evidence are not listed here. They are out of the test sample, not evidence gaps, and move to the next test cycle: MDM-CTL-006, MDM-CTL-008, MDM-D07 Sections 4.6 to 4.13 and 4.16, and Section 5.2 (priority).

5. Recommendations

Each recommendation answers one finding or gap. Design findings need a design change. Operating findings need the control performed as written, with evidence. Due dates follow Section 2.4 and run from the date the owner agrees the finding. Every success indicator is checked by retest in MDM-D12.

5.1 Findings

Rec	Finding	Action	Owner	Due	Success Indicator
MDM-REC-001	MDM-FND-001 (Medium, 8)	Record the iOS Share extension path as a platform constraint in MDM-D07 Section 4.4. State that encryption is the protection that still applies. Submit the remaining exposure to the Business Owner to accept it or to require a different iOS BYOD access model.	IT Operations Manager; decision by the Business Owner	90 days	The constraint is documented, and the Business Owner's decision is recorded in MDM-D12. A retest confirms that shared files still cannot be opened outside managed apps.

Rec	Finding	Action	Owner	Due	Success Indicator
MDM-REC-002	MDM-FND-002 (Medium, 9)	Deploy the OneDrive app configuration required by MDM-D08 to corporate iOS devices and provide MDM-EVD-007. Check the other five approved apps for the same bypass.	IT Operations Manager	90 days	A noncompliant corporate iPhone is blocked in OneDrive and in the other approved apps (MDM-TST-002, steps 11–12 repeated).
MDM-REC-003	MDM-FND-003 (Medium, 6)	Perform and record the CISO review of the IT Operations Manager's access. Add the manager's access as a separate line in the quarterly review record.	CISO	90 days	The next two quarterly reviews show a recorded CISO decision for the manager's access. Internal Audit validates closure.
MDM-REC-004	MDM-FND-004 (Medium, 6)	Perform the current monthly baseline review. Schedule each review as a recurring task with a named backup reviewer.	IT Operations Manager	90 days	Three consecutive monthly reviews are recorded in MDM-EVD-014.
MDM-REC-005	MDM-FND-005 (Medium, 6)	Define and approve an immediate-lock configuration for each approved Android model and record it in MDM-EVD-002. Measure the unlock window after screen-off. If a model cannot enforce immediate lock, record it as a constraint and set the shortest supported value.	IT Operations Manager	90 days	MDM-EVD-002 lists a configuration per model. A retest shows a PIN is required on wake after screen-off, with the window measured.
MDM-REC-006	MDM-FND-006 (Medium, 6)	Confirm that access is blocked for the departure verified by account status only. Add sign-in failure evidence as a required	IT Operations Manager	90 days	Every contractor departure in the next 90 days has effective-block evidence. Any

Rec	Finding	Action	Owner	Due	Success Indicator
		field in the offboarding record.			incomplete action is escalated as MDM-D07 Section 5.8 requires.
MDM-REC-007	MDM-FND-007 (Medium, 6)	Confirm the wipe status of the lost device now. If it is still unconfirmed, keep it open with an owner and a follow-up date. Add confirmation, owner and follow-up date as required fields in the loss record.	IT Operations Manager (interim)	90 days	The lost-device record shows confirmation or active tracking. Every new loss record has the three fields completed.
MDM-REC-008	MDM-FND-008 (Low, 4)	Set a retention period for BYOD activation records with the data owner and legal or privacy input. Configure it in the repository and remove records past the period.	IT Operations Manager (interim)	180 days	The retention period is approved and configured, with evidence added to MDM-EVD-064.
MDM-REC-009	MDM-FND-009 (Medium, 6)	In the next revision of MDM-D05, add controls for encryption, data removal, the BYOD notice and browser access. Assign a Control Owner to each and link each to a risk in MDM-D04, new or existing. Map data removal to NCA ECC 2-6-3-3 in the crosswalk.	CISO; GRC Analyst prepares the draft	90 days	Each of the four areas has a control ID, an owner and a linked risk in MDM-D05. The next test plan includes them. Owners named in MDM-REC-007 and 008 move to the new control owners.

5.2 Assurance Gaps

Rec	Gap	Action	Owner	Due	Success Indicator
MDM-	MDM-CTL-	Provide MDM-EVD-	IT	90 days	MDM-EVD-023 is

Rec	Gap	Action	Owner	Due	Success Indicator
REC-010	004 (MDM-EVD-023 Not Provided)	023 and include MDM-CTL-004 in the next test sample.	Operations Manager		Accepted in MDM-D09, and the control has a test result.
MDM-REC-011	Encryption in transit (MDM-EVD-057 Not Provided)	Provide MDM-EVD-057 and review the network path for proxy or TLS inspection.	IT Operations Manager	90 days	MDM-EVD-057 is Accepted, and the review result is recorded.
MDM-REC-012	Enterprise user MFA, A-06 (MDM-EVD-069 Partial)	Obtain written confirmation of MFA coverage from the IAM owner.	CISO, with the IAM owner	90 days	Written confirmation is filed in MDM-EVD-069. If coverage is incomplete, a finding is raised.

Assurance gaps have no severity. They take the 90-day timeline so they are resolved before the next test cycle.

5.3 Priority

Work starts with the highest scores: MDM-REC-002 (9), then MDM-REC-001 (8). The six Medium findings scored 6 follow, then MDM-REC-008 (Low). MDM-REC-009 runs alongside the others because it fixes the root cause behind MDM-FND-007 and 008.

6. Items for Risk Owner Decision

Four items need a decision that only the Risk Owner can make. The Control Owner supplies the facts and the options. The decision and its date are recorded in MDM-D12. No finding has an Impact score of 5, so no item needs mandatory management review under rule R5.

Item	Risk	Risk Owner	Facts	Options	GRC View
D-01: Access window after loss of compliance (L-02)	MDM-RSK-003, Medium (9)	Business Owner	An open session kept access for 6 hours 10 minutes after the device became noncompliant, until token renewal (MDM-TST-005, step 17). This is within the 28-hour bound in MDM-D08 Section 4.2. After an account was disabled,	1. Accept the window up to the 28-hour bound. 2. Ask IT Operations to assess options to shorten it,	The window is within the designed bound, so it is not a finding. Its length differs sharply from account revocation. Option 2 is

Item	Risk	Risk Owner	Facts	Options	GRC View
			access ended in 3 minutes (MDM-TST-007, step 8).	then decide.	advised before accepting, so the decision rests on known alternatives.
D-02: iOS Share extension exposure (MDM-FND-001, MDM-REC-001)	MDM-RSK-002, High (12)	Business Owner	Encrypted corporate files can be moved to unmanaged apps on iOS BYOD. The receiving app could not open them (MDM-TST-001, step 14). App Protection cannot block this path on unenrolled devices (MDM-D07 Section 4.4).	1. Accept the exposure, with encryption as the protection that applies. 2. Require a different access model for iOS BYOD.	Option 1 is reasonable while files stay unreadable. If evidence shows a copy can be read outside managed apps, the finding is re-rated and the decision is revisited.
D-03: Android immediate lock, if a model cannot enforce it (MDM-FND-005, MDM-REC-005)	MDM-RSK-001, Medium (9)	Business Owner	Corporate Android devices unlocked without a PIN 15 seconds after screen-off (MDM-TST-006, step 8). The full window is not yet measured.	Decided only if MDM-REC-005 finds a model that cannot enforce immediate lock: 1. Accept the measured window for that model. 2. Remove the model from the approved	No decision is needed until the window is measured.

Item	Risk	Risk Owner	Facts	Options	GRC View
				list.	
D-04: BYOD without MDM enrollment, against SAMA CSF 3.3.10 consideration 4(e)	MDM-RSK-002, High (12)	Business Owner; the CISO advises	Consideration 4(e) expects the BYOD standard to cover MDM, access controls on the device and the business container, and encryption on the personal device for transmission and storage. Personal devices are not enrolled by design (MDM-D07 Section 4.4). Container access controls and encryption at rest are applied and tested (MDM-TST-001, steps 15–16). Encryption in transit is unverified (MDM-REC-011). MDM-D05 maps MDM-CTL-002 to considerations 4(c) and 4(d) only.	1. Accept the deviation, with app-level controls as the alternative, and record the rationale in the MDM-D05 crosswalk. 2. Require MDM enrollment for BYOD, with the privacy impact that brings.	Option 1 is defensible because the container controls serve the objective of protecting data in transmission and storage. It should be accepted only after MDM-REC-011 confirms encryption in transit. The deviation must be documented, not left implicit.

The Current Residual Risk field in MDM-D04 is not changed here. It is updated in MDM-D12 from the MDM-D10 results and these decisions.

7. Assumptions and Limitations

7.1 Assumptions

ID	Assumption
AS-01	The MDM-D10 results reflect how the controls operate across the period, not only on the test date.
AS-02	The MDM-D04 Impact and Likelihood scales apply to findings as well as to risks.
AS-03	Where a finding has no linked risk, the closest MDM-D04 risk with a matching

ID	Assumption
	scenario is a fair basis for its rating and ceiling.
AS-04	Owners agree each finding promptly, so due dates start soon after this register is issued.

7.2 Limitations

ID	Limitation
LM-01	No tenant was configured. All findings, ratings and dates are simulated.
LM-02	Ratings rely on MDM-D04 scales, which do not cover regulatory impact. Regulatory exposure, such as under NCA ECC, is noted but not scored.
LM-03	Likelihood is judged from a small sample. Most populations were below the sampling threshold and were tested in full.
LM-04	Assurance Gaps are not rated, so the register may understate exposure in those areas until they are tested.
LM-05	Some values are not yet measured: the Android unlock window (MDM-FND-005) and whether shared iOS files can be read outside managed apps (MDM-FND-001). Ratings may change after retest.
LM-06	Items deferred in MDM-D10 Section 5 were not assessed and are not reflected in this register.

8. Sources

Platform behavior is cited through the project documents that reviewed it, mainly MDM-D07 and MDM-D08. The only new external page is SAMA CSF 3.3.10, reviewed on 7 November 2026.

Source	Used In
MDM-D04 Risk Assessment Methodology and Risk Register	2.3, 3, 4, 5, 6
MDM-D05 Control Requirements and Framework Crosswalk	3, 4, 5
MDM-D06 Mobile Device and BYOD Policy	4.2
MDM-D07 MDM Security Standard	3, 4, 5, 6
MDM-D08 Conditional Access Control Design	4, 5, 6
MDM-D09 Evidence Request List and Evidence Index	4, 5
MDM-D10 Control Testing Workbook	1, 3, 4, 5, 6

Source	Used In
NCA Essential Cybersecurity Controls (ECC-2:2024) - https://cdn.nca.gov.sa/api/files/public/upload/86e09090-44e4-481f-bc28-355673607654_ECC--2024-EN.pdf	3.1, 4.2, 5
SAMA Cyber Security Framework, 3.3.10 Bring Your Own Device (BYOD) - https://rulebook.sama.gov.sa/en/node/3943	6